

HTB Starting Point — Tier 0

FAWN

Guía de Teoría: Protocolo FTP

Preparación pre-máquina · RedTeamLab 2026

Cert path: CPTS → OSCP+

¿Qué aprenderás con esta guía?

Fawn es la segunda máquina del Starting Point. Su vector es **FTP con acceso anónimo habilitado**. Esta guía te prepara teóricamente para entender *por qué* funciona el ataque, no solo ejecutarlo.

■ Objetivo de estudio: entender FTP lo suficientemente bien para que, cuando lo veas en un escaneo nmap, ya sepas exactamente qué intentar y por qué.

1. ¿Qué es FTP?

FTP (File Transfer Protocol) es un protocolo de red estándar para la transferencia de archivos entre un cliente y un servidor. Fue definido en **RFC 959** (1985) y es uno de los protocolos de aplicación más antiguos de Internet.

Opera en la capa de aplicación del modelo OSI y usa **TCP** como protocolo de transporte. Por diseño, FTP *no cifra nada*: ni credenciales ni datos.

Puertos estándar

Puerto	Uso	Descripción
21/TCP	Control	Canal de comandos: autenticación, navegación, órdenes
20/TCP	Datos (Activo)	Transferencia de archivos en modo activo
Dinámico	Datos (Pasivo)	Puerto negociado en modo pasivo (>1024)

2. Modos de Transferencia: Activo vs Pasivo

Esta distinción es clave en pentesting porque afecta cómo se establecen las conexiones y qué reglas de firewall aplican.

Modo Activo (PORT)

1. El cliente se conecta al puerto **21** del servidor (canal de control).
2. El cliente abre un puerto local aleatorio y se lo comunica al servidor con el comando **PORT**.
3. El servidor inicia la conexión de datos **desde su puerto 20** hacia el puerto del cliente.

■■ Problema: el servidor intenta conectarse AL cliente. Si el cliente está detrás de un NAT o firewall, esta conexión entrante frecuentemente falla.

Modo Pasivo (PASV) — el más común hoy

1. El cliente se conecta al puerto **21** del servidor.
2. El cliente envía el comando **PASV**.
3. El servidor abre un puerto aleatorio (>1024) y se lo comunica al cliente.

4. El cliente inicia la conexión de datos hacia ese puerto del servidor.

■ Ventaja: el cliente siempre inicia ambas conexiones. Funciona bien detrás de NAT/firewall. Por esto la mayoría de clientes modernos usan PASV por defecto.

Comparación rápida

Aspecto	Activo (PORT)	Pasivo (PASV)
¿Quién inicia datos?	El servidor → cliente	El cliente → servidor
Puerto datos servidor	20/TCP	Aleatorio >1024
Problemas con NAT	Frecuentes	Raros
Uso típico hoy	Legacy, entornos controlados	Mayoría de clientes modernos
Relevancia pentest	Útil en redes internas	El que verás en la práctica

3. Autenticación en FTP

FTP soporta dos modos de autenticación principales:

Autenticación con credenciales

Usuario y contraseña enviados en **texto plano** por el canal de control (puerto 21). Cualquier herramienta de captura de red (Wireshark, tcpdump) puede leer las credenciales directamente.

```
USER admin
331 Password required
PASS secreto123
230 User logged in
```

Acceso Anónimo (Anonymous FTP) — vector de Fawn

Muchos servidores FTP permiten acceso sin credenciales reales usando el usuario **anonymous**. La contraseña puede ser cualquier cosa (convencionalmente un email).

```
USER anonymous
331 Send your complete email address as password.
PASS cualquier@cosa.com
230 Anonymous user logged in
```

■ El acceso anónimo fue diseñado para distribución pública de archivos (software, documentos). Cuando está mal configurado, expone archivos internos o permite subir archivos maliciosos.

En pentesting, siempre que veas **puerto 21 abierto**, el primer intento es:

- usuario: **anonymous** — contraseña: (vacía o cualquier email)
- usuario: **ftp** — contraseña: (vacía)
- Buscar credenciales en DefaultCreds-Cheat-Sheet para el servicio/appliance específico

4. Comandos FTP Esenciales

Estos son los comandos que usarás en la máquina y en engagements reales:

Comando	Descripción	Ejemplo
USER / PASS	Autenticación	USER anonymous
ls / dir	Listar archivos	ls -la
cd	Cambiar directorio	cd /pub
get	Descargar un archivo	get flag.txt
mget	Descargar múltiples	mget *.txt
put	Subir un archivo	put shell.php
mput	Subir múltiples	mput *.php
pwd	Directorio actual	pwd
binary	Modo binario (para archivos)	binary
ascii	Modo texto	ascii
quit / bye	Cerrar sesión	quit
passive	Toggle modo pasivo	passive

Flujo completo de una sesión FTP desde terminal

```
# Conectar
ftp 10.129.X.X

# Dentro del cliente FTP:
Name: anonymous
Password: (Enter o email)

# Navegar y descargar
ls -la
cd /pub
binary          # importante para archivos no-texto
get flag.txt
mget *          # descargar todo
quit
```

5. Enumeración FTP con Nmap

Nmap tiene scripts NSE específicos para FTP que automatizan parte de la enumeración:

Scripts NSE para FTP

Script NSE	Qué hace
ftp-anon	Detecta si anonymous login está habilitado y lista archivos
ftp-syst	Identifica el tipo de sistema FTP (SYST response)
ftp-brute	Fuerza bruta de credenciales
ftp-bounce	Detecta FTP bounce attack
ftp-vsftpd-backdoor	Detecta backdoor en vsftpd 2.3.4 (CVE-2011-2523)
ftp-libopie	Detecta vulnerabilidad OPIE en wu-ftp

Comandos nmap para FTP

```
# Escaneo básico con detección de versión
nmap -sV -p 21 10.129.X.X

# Scripts FTP específicos
nmap -p 21 --script ftp-anon,ftp-syst 10.129.X.X

# Todos los scripts FTP
nmap -p 21 --script "ftp-*" 10.129.X.X

# Resultado esperado si anon está habilitado:
# 21/tcp open  ftp  vsftpd 3.0.3
# | ftp-anon: Anonymous FTP login allowed
# | -rw-r--r-- 1 0 0 32 Jun 04 09:48 flag.txt
```

6. FTP y Seguridad — Por qué es Problemático

FTP tiene problemas estructurales de seguridad que lo hacen inaceptable en entornos modernos:

1. Transmisión en texto plano

Todas las credenciales y todos los datos se transmiten sin cifrar. Un atacante con acceso al segmento de red puede capturar credenciales con:

```
# Capturar credenciales FTP con tcpdump
sudo tcpdump -i eth0 -A 'port 21' -n

# Con Wireshark: filtro
ftp
```

2. Anonymous FTP mal configurado

Cuando anonymous login está habilitado sin restricciones:

- **Lectura:** expone archivos internos, configuraciones, contraseñas en texto plano
- **Escritura:** permite subir webshells o archivos maliciosos (si el servidor sirve HTTP también)
- **Pivot:** los archivos descargados pueden contener credenciales para otros servicios

3. Versiones vulnerables

Algunos servidores FTP tienen CVEs críticos conocidos:

Software	Versión	CVE	Impacto
vsftpd	2.3.4	CVE-2011-2523	Backdoor — RCE como root
ProFTPD	1.3.5	CVE-2015-3306	mod_copy RCE sin auth
wu-ftp	2.6.0	CVE-2001-0680	Directory traversal
FileZilla Server	<0.9.41	CVE-2014-0166	Auth bypass

7. MITRE ATT&CK; Mapping — FTP

Cuando explotamos FTP en un engagement real, estas son las técnicas relevantes:

Táctica	Técnica	ID	Aplicación en FTP
Reconnaissance	Network Service Discovery	T1046	nmap detecta FTP abierto
Initial Access	Valid Accounts: Default Accounts	T1078.001	Login anonymous o credenciales por defecto
Collection	Data from Network Shared Drive	T1039	Descarga de archivos via get/mget
Exfiltration	Exfiltration Over Alternative Protocol	T1048	Uso de FTP para exfiltrar datos
Lateral Movement	Remote File Copy	T1105	Transferencia de herramientas al objetivo via put
Credential Access	Credentials in Files	T1552.001	Archivos con contraseñas en el servidor FTP

8. Perspectiva Defensiva

Como Red Teamer, entender la defensa te hace mejor atacante: sabes qué deja rastros y cómo evadir detección.

¿Qué detectaría un Blue Team?

Fuente de log	Qué registra
vsftpd logs (/var/log/vsftpd.log)	Conexiones, logins exitosos/fallidos, comandos ejecutados
Sistema de archivos	Timestamps de acceso en archivos descargados (atime)
Firewall/IDS	Conexiones entrantes a TCP/21 desde IPs no conocidas
Snort/Suricata	Reglas para 'ftp anonymous login' o descarga masiva (mget)
Network capture	Credenciales en texto plano si hay captura de tráfico

Remediación correcta

- **Deshabilitar FTP anónimo:** `anonymous_enable=NO` en `vsftpd.conf`
- **Reemplazar FTP por SFTP/FTPS:** SFTP usa SSH (puerto 22, cifrado completo). FTPS añade TLS a FTP.
- **Restringir acceso:** listas de IPs permitidas, VPN obligatoria para acceso FTP
- **Permisos mínimos:** el usuario FTP solo debe leer/escribir su directorio asignado (`chroot jail`)
- **Auditar archivos:** revisar qué está expuesto en el servidor FTP antes de dejarlo activo

■ En el CPTS, te preguntarán cómo remedias las vulnerabilidades que encuentras. Memoriza siempre el par: vulnerabilidad ↔ remediación.

9. Checklist Pre-Ataque FTP

Cuando veas **puerto 21 abierto** en un escaneo, sigue este orden:

- [] 1. `nmap -sV -p 21 --script ftp-anon,ftp-syst <IP>`
- [] 2. Intentar: `ftp <IP>` → user: anonymous → pass: (enter)
- [] 3. Si entra: `ls -la`, explorar directorios, buscar flags y credenciales
- [] 4. Descargar TODO: `mget *` (modo binary para archivos no-texto)
- [] 5. Si no entra anon: buscar credenciales por defecto del servicio
- [] 6. Verificar versión del servidor (SYST) → buscar CVEs
- [] 7. Comprobar si el servidor también sirve HTTP → pensar en subir webshell
- [] 8. Documentar: versión FTP, permisos encontrados, archivos descargados

10. Preguntas de Estudio — Autoevaluación

Responde estas preguntas antes de atacar la máquina. Si no puedes responderlas, repasa las secciones correspondientes.

1. ¿En qué se diferencia el modo activo del modo pasivo en FTP? ¿Cuál es el problema del activo con NAT?

-
2. ¿Por qué FTP es considerado inseguro para transmitir credenciales? ¿Qué herramienta usarías para capturarlas?
-
3. ¿Qué usuario y contraseña se usan para el acceso anónimo FTP? ¿Por qué existe esta funcionalidad?
-
4. ¿Qué script NSE de nmap usarías para detectar si anonymous login está habilitado?
-
5. ¿Qué comando FTP usas para descargar un archivo? ¿Y para descargar todos los archivos de un directorio?
-
6. ¿Por qué es importante ejecutar el comando **binary** antes de descargar archivos que no son texto plano?
-
7. ¿Qué CVE famoso tiene vsftpd 2.3.4 y cuál es su impacto?
-
8. Si encuentras anonymous FTP con permiso de escritura y el servidor también tiene HTTP activo, ¿qué intentarías?
-
9. ¿Qué alternativas seguras a FTP existen y por qué son superiores?
-
10. ¿Qué táctica y técnica MITRE corresponde al acceso via anonymous FTP?
-

11. Referencias

- **RFC 959** — FTP Protocol Specification: <https://datatracker.ietf.org/doc/html/rfc959>
- **HackTricks FTP Pentesting**: <https://book.hacktricks.xyz/network-services-pentesting/pentesting-ftp>
- **MITRE T1078.001**: <https://attack.mitre.org/techniques/T1078/001/>
- **vsftpd 2.3.4 Backdoor**: <https://www.cvedetails.com/cve/CVE-2011-2523/>
- **nmap ftp-anon script**: <https://nmap.org/nsedoc/scripts/ftp-anon.html>
- **HTB Starting Point — Fawn**: <https://app.hackthebox.com/starting-point>